pharama-navi.com セキュリティ設定の診断・改善レポート

作成：yuto H ／ 実施：2026 年 10 月 24 日〜27 日

1. 概要

自分が企画・運用している訪日外国人向け OTC 医薬品情報サイト（pharama-navi.com）を対象に、公開ツールでセキュリティ設定を診断し、見つかった課題を修正して再確認した記録です。サイトの HTML は Claude Code で生成した内容を元に、自分で修正して運用しています。診断結果の読み解きや設定の検討にも、AI（Claude）に相談しながら進め、設定の変更と再確認は自分で実施しました。

主な成果は次のとおりです。

- MDN HTTP Observatory：70 点（B）から 125 点（A+）へ。合格項目は 10/12 から 12/12 へ
- OWASP ZAP：アラート 10 件（中 6・低 1・情報 3）から 3 件（中 2・情報 1）へ
- ツールの指摘とは別に、デプロイが失敗した際のログを AI（Claude）に読み解いてもらう中で、.git ディレクトリが公開状態になっている可能性が見つかり、自分で実際に確認したうえで修正した

2. 対象と方法

対象：https://pharama-navi.com（自分が運営するサイトのみ）

構成：GitHub のリポジトリと Cloudflare（Workers の静的アセット機能）で配信する静的サイト。問い合わせフォームは外部サービス（Formspree）へ送信しています。外部サービスとして、Google Fonts と Cloudflare Web Analytics を利用しています。

使用ツール

ツール	見るもの
MDN HTTP Observatory	HTTP ヘッダー、リダイレクト、CSP、SRI などの設定
Security Headers	セキュリティヘッダーの有無と評価

ツール	見るもの
SSL Labs（Qualys）	HTTPS/TLS の設定
OWASP ZAP 2.17.0	プロキシ経由の巡回とパッシブ検査、自動スキャン（アクティブスキャンも実行したが、送信されたリクエストは 2 件（存在しない URL への GET と、トップページへの POST）のみで、新規アラートなし）

評価の考え方：ツールのリスク評価は一般的な基準によるものです。入力を受け付けない静的サイトでの実際の影響は別に考える必要があるため、「ツールの評価」と「このサイトでの実リスク（筆者の判断）」を分けて記載しています。

3. 改善前後の結果

ツール	改善前	改善後
MDN HTTP Observatory	70/100（B）、10/12 合格	125/100（A+）、12/12 合格（10 月 25 日）
OWASP ZAP	10 件（中 6・低 1・情報 3）	3 件（中 2・情報 1）（2026 年 10 月 25 日）
Security Headers	改善前の記録なし	A+（2026 年 10 月 25 日。HSTS を含む 6 項目すべて合格）
SSL Labs	A-（4 エンドポイントすべて）	A-（変化なし。TLS 設定は Cloudflare が管理）

4. 発見事項と対応

F-1 .git ディレクトリの公開

- **発見**：Cloudflare のデプロイログに、.git 配下のファイル（.git/logs/HEAD、.git/index）が公開用アセットとしてアップロードされた記録があった。自動ツールでは検出されておらず、デプロイ失敗時のログを AI（Claude）に読み解いてもらう中で、その記録が見つかった。

- **確認**：ブラウザで /.git/HEAD にアクセスし、コミットのハッシュ値が表示されることを確認した（修正前の画面を保存）。
- **原因**：配信ディレクトリがリポジトリのルート全体を指す設定だった。Cloudflare Pages は .git などを自動で除外していたが、Workers の静的アセットでは自動では除外されない。
- **リスク評価（筆者）**：中。HTML や CSS はもともと公開情報であり、個人情報や機密情報はリポジトリに含めていない。一方で、コミット履歴やコミットに記録されたメールアドレスなどが読まれる可能性があった。修正前に .git/config などの内容までは確認していないため、他のファイルが取得できた可能性は排除できない。
- **対応**：リポジトリ直下に .assetsignore を作成し、.git などを配信対象から除外した。
- **再確認**：修正後、/.git/HEAD が表示されなくなったことを、別のブラウザでも確認した。あわせて、.git/config、.gitignore、.assetsignore、README.md、wrangler.json も取得できないことを確認した。10 月 27 日には、curl でも /.git/HEAD と /.git/config が 404 であることを再確認した（付録 A）。
- **追加対応**：コミットに使うメールアドレスの非公開設定が無効だったため、有効にした。過去のコミットに記録済みのアドレスは残るが、履歴の書き換えは行っていない。

F-2 CSP（Content-Security-Policy）が緩い

- **発見**：ZAP が CSP 関連の 5 件（重要ディレクティブの定義漏れ、script-src の unsafe-eval と unsafe-inline、style-src の unsafe-inline、ワイルドカード）を中リスクとして検出。Observatory は CSP で 20 点の減点。
- **原因**：初期設定が次の内容で、HTTPS であれば任意のオリジンの読み込みと、インラインスクリプトの実行を許可する状態だった。

```
default-src 'self' https: data: 'unsafe-inline' 'unsafe-eval'
```

- **リスク評価（筆者）**：ツールの評価は中。現状はユーザー入力を画面に出力する機能がなく、悪用される可能性は低い。ただし、広告の導入など機能を増やす際の防御として意味がある。
- **対応（段階的に実施）**：
    a. 厳しい案を Content-Security-Policy-Report-Only で試験運転し、現行の CSP と併用した。DevTools の Console で違反を収集した。
    b. 実際に使っている外部サービスだけを許可した（Google Fonts、Cloudflare Web Analytics、Formspree）。

c. サブページ（about、articles、privacy、contact）のインラインの style と script を外部ファイルに分離し、contact ページの style 属性は CSS のクラスに置き換えた。
d. 全ページで Console の警告がゼロになったことを確認してから、本番に適用した。

- **適用した CSP**：

```
default-src 'none'; script-src 'self' https://static.cloudflareinsights.com; style-src 'self' https://fonts.googleapis.com; img-src 'self' data:; font-src 'self' https://fonts.gstatic.com; connect-src 'self' https://formspree.io https://cloudflareinsights.com; base-uri 'self'; form-action 'self' https://formspree.io; frame-ancestors 'none'; object-src 'none'
```

- **再確認**：Observatory の CSP が+10 点（default-src が none、unsafe なし、form-action 設定あり）。ZAP の CSP 関連アラートが消えた。

F-3 HSTS が実質無効（max-age=0）

- **発見**：ZAP が Strict-Transport-Security を低リスクで検出。応答ヘッダーに max-age=0 が入っており、ヘッダーはあるが無効な状態だった。
- **対応**：Cloudflare のダッシュボードで HSTS の期間を設定した。同じヘッダーを _headers にも書くと二重になり値が壊れるため、設定は一か所にした。短い期間で設定したのち、Observatory が HSTS を 6 か月未満と指摘（10 点の減点）したため延長した。現在の期間：12 か月。includeSubDomains と preload は付けていない。curl でも max-age=31536000（12 か月）で配信されていることを確認した（付録 A）。
- **再確認**：Observatory で HSTS が合格（12/12）。Security Headers でも HSTS が合格し、ZAP の HSTS アラートも消えた。

F-4 問い合わせフォーム

- **発見**：送信先の ID がテンプレートのまま（YOUR_FORM_ID）で、フォームが送信できない状態だった。また、form タグに method と action がなく、JavaScript が動かない場合は GET で送信され、入力内容が URL に含まれる可能性があった。ZAP がパラメータ付きの GET で /contact を記録していた。
- **対応**：Formspree でフォームを作成して ID を設定し、本番で送信テストを行った。あわせて、form タグに method=POST と action（Formspree）を追加し、JavaScript が動かない場合でも入力内容が URL に含まれないようにした。
- **リスク評価（筆者）**：低から中。機能不全が主で、個人情報が URL に載る可能性は予防的に対処した。

5. 対応しなかった項目と理由

項目	ツールの評価	判断	理由
サブリソース整合性（SRI）の欠落	中	許容	原因は Google Fonts の CSS。ブラウザごとに返す内容が変わるため、SRI の固定は現実的でない。将来、フォントを自サイトで配信すれば解消できる。なお Observatory の SRI（スクリプトが対象）は合格
Anti-CSRF トークンなし	中	許容	認証やセッションがなく、状態を変更する機能もない問い合わせフォームのみのため、CSRF で狙える対象がない。スパム対策は別の課題として扱う
Cache-Control の再確認	情報	許容	静的サイトであり、影響は小さい
SSL Labs が A-	-	現状維持	TLS の設定は Cloudflare が管理している

6. 作業中に起きた不具合と学び

1. **_headers の書式エラーでデプロイが失敗**：パスの行（/*）が字下げされていたため、Expected a path before headers というエラーでデプロイが止まった。エラーの原因は、ログの末尾ではなく、その上の行に書かれていた。公開中のサイトは、最後に成功した版が配信され続けていたため、影響はなかった。
2. **CSP の適用でサブページの表示が崩れた**：厳しい CSP がブロックとして働いた状態で、articles、privacy、contact の表示が崩れた。原因はインラインの style と script だった。トップページだけで判断せず、Report-Only の段階で全ページと各操作を確認する必要があった。
3. **HTML の記述ミス**：articles.html の link タグの閉じ引用符が抜けており、CSS が読み込まれなかった。Console にエラーが出ないため、CSP が原因だと誤解しやすかった。Console が空のときは、CSP 以外の記述ミスも疑う。
4. **ZAP の古いアラート**：ZAP は古いアラートを自動では消さないため、新しいセッションで巡回し直して再測定した。

7. 今後の課題

- Google Fonts を自サイトで配信し、SRI の課題と外部許可の数を減らす
- 広告（AdSense）を導入する際は、外部オリジンの許可が増えるため、CSP を再評価する
- 記事の描画で innerHTML を使っている。現状は自分で書いた固定データのみだが、ユーザー入力を扱う場合は textContent かエスケープが必要
- HSTS の includeSubDomains と preload は、すべてのサブドメインが HTTPS であることを確認してから検討する
- 月に一度など、定期的に再診断する

8. 診断の範囲と限界

- 設定面（HTTP ヘッダー、TLS、公開ファイル、ツールによる検査）が中心で、手動での確認は curl による単発のリクエスト（ヘッダー、リダイレクト、公開ファイル、HTTP メソッド。付録 A）にとどまり、認可やロジックの手動診断は行っていません。ZAP のアクティブスキャンは 2 リクエストのみで、動的な脆弱性検査としては限定的です。
- 静的サイトのため、データベース、認証、サーバー側の処理に関する脆弱性は、該当する機能がなく対象外です。
- ツールの結果は網羅的ではなく、スコアは安全性の保証ではありません。
- 外部サービス（Formspree など）側の設定は対象外です。
- 診断は自分が運営するサイトのみに実施しました。
- 本レポートの内容は 2026 年 10 月 27 日時点のものです。

付録 A. 手動での確認（curl）

実施日時：2026 年 10 月 28 日 01:13〜01:14 UTC（日本時間 10:13〜10:14）。同じ内容を、10 月 27 日にも別の環境で実施し、同じ結果を得ている

実施環境：VMware Workstation 上の Ubuntu 26.04.1 LTS（カーネル 7.0.0-30-generic、ホスト名 ubuntu）。10 月 27 日の初回は、別の Linux 環境（Ubuntu 24.04.5 LTS、カーネル 6.17.0-1012-aws）で実施した

対象：https://pharama-navi.com（自分が運営するサイトのみ）。いずれも単発のリクエストで、負荷をかける検査は行っていません。

確認内容	コマンド	結果	判断

確認内容	コマンド	結果	判断
レスポンスヘッダー	curl -sI https://pharama-navi.com/	HTTP/2 200。CSP、HSTS（max-age=31536000）、X-Frame-Options: DENY、X-Content-Type-Options: nosniff、Referrer-Policy、Permissions-Policy を確認	設定どおり。CSP は 4 章 F-2 で適用した内容と一致
HTTP から HTTPS への転送	curl -sI http://pharama-navi.com/	301 Moved Permanently、Location: https://pharama-navi.com/	問題なし
.git の公開（HEAD）	curl -s -o /dev/null -w "%{http_code}\n" https://pharama-navi.com/.git/HEAD	404	F-1 の修正を再確認
.git の公開（config）	上と同じ形式で /.git/config	404	F-1 の修正を再確認
許可される HTTP メソッド	curl -s -i -X OPTIONS https://pharama-navi.com/	405 Method Not Allowed。エラー応答にも各セキュリティヘッダーが付与されている	OPTIONS は許可されていない

補足

- レスポンスの report-to ヘッダーには、Cloudflare が付与するエラー報告用の識別子（URL 内のトークン）が含まれるため、出力の全文は掲載せず、必要な項目だけを抜粋しています。
- HSTS は 12 か月で、includeSubDomains と preload は付いていないことを、実際のレスポンスで確認しました。
- 診断ツールとは別に、自分でリクエストを送り、結果を読んで判断する作業を行ったという位置づけで、ペネトレーションテストではありません。
- 画面表示では、grep で report-to と nel の行を除外しています（識別子を含むため）。
- VMware 上での実施時に、オプションの入力ミス（ヘッダー取得の -sI を小文字の -sl と入力、OPTIONS で -o と -X を取り違え）があり、出力が HTML 本文になったことで気づいて、正しいコマンドで再実行しました。本付録の結果は、再実行後の出力です。

- 10 月 27 日と 28 日の 2 回で、ヘッダー、HTTP から HTTPS への転送、.git の応答（404）、OPTIONS の応答（405）は、同じ結果でした。